

Junior Cloud Security Engineer

Internship Task Report

Intern Full Name	[REDACTED]
Intern Email	[REDACTED]
Cohort	Cohort 7 2026
Task ID	CSE-IAM-L-026-04
Task Title	IAM Privilege Escalation Path Analysis and Risk Mitigation
Skill Domain	Identity and Access Management (IAM) / Cloud Privilege Escalation
Difficulty Level	Advanced
CPE Credits	4 CPE Credits
Guiding Framework(s)	MITRE ATT&CK / IAM least privilege / AWS security best practices
Submission Date	31 August 2026

1.0 Task Overview

Task ID	CSE-IAM-L-026-04
Task Title	IAM Privilege Escalation Path Analysis and Risk Mitigation
Skill Domain	Identity and Access Management (IAM) / Cloud Privilege Escalation
Difficulty	Advanced
Duration	14 Hours
CPE Credits	4 CPE Credits
Cloud Platform(s)	AWS sandbox account; local Docker/WSL lab; Cybr hosted labs
AWS Region(s) Used	us-east-1 (primary); PMapper attempted other regions before region-scoped rerun
Primary Tools	AWS CLI, Cloudsplaining, PMapper/Principal Mapper, Docker Desktop, IAM Vulnerable, browser; Cybr labs
Target Environment	iam-vulnerable local lab; AWS sandbox IAM; Cybr IAM labs
MITRE ATT&CK IDs	T1078 (Valid Accounts); T1098 (Account Manipulation); T1068 (Exploitation for Privilege Escalation)
Guiding Frameworks	MITRE ATT&CK; least privilege; identity governance and monitoring
Regulatory Alignment	ISO/IEC 27001 access control and identity management principles

1.1 Introduction

This task assessed how overly permissive AWS IAM permissions can create privilege-escalation paths from lower-privileged identities to more powerful users or roles. Static policy analysis and relationship mapping were combined with an isolated local lab to identify risky IAM capabilities and translate them into practical remediation priorities.

1.2 Objectives & Learning Outcomes

The work focused on the following measurable outcomes:

- Assess IAM policies for privilege-escalation and resource-exposure risk — completed using Cloudsplaining analysis.
- Deploy an isolated vulnerable IAM homelab — completed with Docker and a local web interface on port 8080.
- Map privilege-escalation relationships — completed with PMapper, including generation of a privilege-escalation risk graph.
- Identify and prioritize risky IAM paths — completed by reviewing high-risk policy findings and PMapper escalation relationships.
- Apply and document mitigation concepts — incorporated into the risk matrix, recommendations, and hosted-lab plan.

1.3 Scope & Legal Authorisation

All technical activity was limited to authorised training and sandbox environments. No production systems, external customer environments, or real customer data were intentionally accessed.

Authorised environments used:

- AWS sandbox account used for IAM enumeration and PMapper analysis (account identifier redacted in this report).
- Local iam-vulnerable simulation hosted through Docker Desktop/WSL.
- Local browser interface at localhost:8080 for viewing intentionally vulnerable IAM roles.
- Cybr IAM challenge labs for PutRolePolicy and AttachUserPolicy privilege-escalation practice (completion evidence to be attached when available).

AI assistance was used for explanation, troubleshooting guidance, risk analysis, and report drafting only. Technical commands and evidence were produced in the authorised lab by the intern.

1.4 MITRE ATT&CK Cloud Threat Mapping

MITRE ATT&CK Technique ID	Technique Name	Relevance to This Task
T1078	Valid Accounts	Compromised or manipulated valid IAM identities can be used to exercise permissions and move toward higher privilege.
T1098	Account Manipulation	IAM policy attachment and login-profile modification can alter an identity to establish or increase access.
T1068	Exploitation for Privilege Escalation	The task focuses on privilege escalation from lower privilege to administrative capability through IAM permission weaknesses.

2.0 Environment & Tool Setup

2.1 Cloud Architecture Overview

The environment combined an AWS sandbox account for IAM policy and relationship analysis with a local Docker-based IAM Vulnerable lab. The local web interface exposed intentionally vulnerable role examples while Cloudsplaining and PMapper were used to analyze AWS IAM risk and escalation relationships.

Cloud Resource / Component	Type / Service	Role in Task	Region / Config Notes
AWS IAM sandbox	AWS IAM	Source of users, roles, groups and policies for analysis	Primary analysis in us-east-1; identifiers redacted
iam-vulnerable lab	Docker / nginx	Local simulation of vulnerable IAM roles	WSL + Docker Desktop; localhost:8080

Cloud Resource / Component	Type / Service	Role in Task	Region / Config Notes
Cloudsplaining report	IAM static analysis	Identified risky policy categories	High-risk privilege escalation and resource exposure observed
PMapper graph	Principal Mapper	Mapped IAM privilege relationships	Generated local graph and privesc-risk PNG
Cybr labs	Hosted training	Practice PutRolePolicy and AttachUserPolicy escalation	Authorised hosted environment; evidence pending

2.2 AWS CLI & Tool Configuration

Tool / Service	Version	Installation Method	Purpose in This Task
AWS CLI	Configured installation	Existing WSL configuration	IAM enumeration and identity/API access
Cloudsplaining	Installed CLI	Python environment	Static IAM policy risk analysis
PMapper / Principal Mapper	Installed CLI	pipx environment	IAM graph creation and privilege-escalation visualization
Docker Desktop	29.7.2	Windows Desktop + WSL integration	Run local IAM Vulnerable simulation
IAM Vulnerable	Repository version used	Git clone / local files	Provide intentionally vulnerable IAM role scenarios
Cybr	Hosted	Browser	Hosted IAM privilege-escalation practice

Key Configuration Commands Used

Configuration was verified through successful AWS IAM data collection, successful Docker container startup, access to the local lab interface, and successful PMapper graph generation. Raw commands and terminal output are retained in the evidence set rather than reproduced in this report.

2.3 AI Tool Usage Declaration

ChatGPT was used to explain tool errors, interpret IAM security concepts, organize findings, and draft professional report language. It was not used to execute AWS actions, fabricate screenshots, or replace the intern's technical evidence.

AI Tool	Used For	What Was NOT Done with AI
ChatGPT	Troubleshooting guidance, IAM risk interpretation, report drafting	Did not execute cloud commands, generate lab screenshots, or create technical findings independently

All technical findings, CLI outputs, configurations, and evidence in this report are the intern's own work.

3.0 Methodology — Phase Execution

Phase A: Theory & Conceptual Foundation

Phase Objective	Review IAM privilege-escalation concepts and establish a policy-risk baseline.
Estimated Time	~90 minutes
Evidence File(s)	phaseA_report.png

Actions Taken

Reviewed IAM privilege-escalation risk categories and analyzed the Cloudsplaining executive summary to establish the initial risk baseline.



Key Observations

Cloudsplaining identified one privilege-escalation instance rated High, one resource-exposure instance rated High, and one infrastructure-modification instance rated Low. These results showed that a small number of IAM weaknesses can still create meaningful blast-radius risk.

Evidence Produced

- phaseA_report.png: The report highlighted privilege escalation and resource exposure as the highest-priority categories.

Phase B: Cloud Environment Setup & Target Preparation

Phase Objective	Deploy the iam-vulnerable environment locally using Docker to simulate exploitable IAM configurations.
Estimated Time	60 minutes
Evidence File(s)	phaseB_docker.png

Actions Taken

Configured Docker Desktop with WSL integration, verified Docker access, cloned the IAM Vulnerable lab content, and started the local containerized simulation. The web interface was then opened locally to confirm the intentionally vulnerable roles were available.



Key Observations

The Docker service initially returned a permission error from WSL. After Docker group/integration configuration, the container started successfully and exposed the lab on port 8080. The interface displayed PassRoleEscalationRole, AttachUserPolicyRole, PutRolePolicyRole, and AssumeRoleEscalationRole.

Evidence Produced

- phaseB_docker.png — screenshot showing the running iam-vulnerable-lab container and port mapping.

Phase C: Core Execution

Phase Objective	Map all possible privilege escalation paths using PMapper and visualize them.
Estimated Time	150 minutes
Evidence File(s)	phaseC_graph.png

Actions Taken

Enumerated IAM roles and created a PMapper graph from the configured AWS profile. Initial PMapper execution required troubleshooting because the installed Python 3.14 environment caused compatibility issues and broad regional enumeration produced connection timeouts. A successful graph was subsequently created and a privilege-escalation visualization was generated.

Key Observations

PMapper identified privilege-escalation relationships involving login-profile manipulation, including roles able to set passwords for more privileged users. The generated graph demonstrates how an apparently limited IAM permission can become a path to administrative access when identity-management actions are too broad.

Evidence Produced

- phaseC_graph.png — PMapper privilege-escalation risk visualization.

Phase D: Independent Extension & Advanced Implementation

Phase Objective	Assess identified escalation paths and define risk-based mitigations.
Estimated Time	~90 minutes
Evidence File(s)	phaseD_policy_before.json, phaseD_policy_after.json

Actions Taken:

Reviewed the privilege-escalation paths identified during the IAM assessment and determined which permissions contributed to excessive privilege. The vulnerable policy was documented before remediation. The policy was then hardened by restricting sensitive IAM permissions to specifically authorized resources. Cloudsplaining was re-run to evaluate whether the changes reduced the identified IAM risk.

Key Observations:

The original policy allowed a sensitive IAM action against unrestricted resources, increasing the possibility of privilege escalation. Applying resource-level restrictions reduced the attack surface while preserving legitimate access. This demonstrated how least-privilege IAM design can mitigate escalation paths without unnecessarily removing required functionality.

Evidence Produced:

- phaseD_policy_before.json — IAM policy configuration before least-privilege remediation.
- phaseD_policy_after.json — Hardened IAM policy demonstrating resource-level restriction.

Evidence Produced

Phase F: Documentation & Reporting

Phase Objective	Compile a professional report summarizing findings, risks, mitigations, and business impact analysis.
Estimated Time	~60–90 minutes
Evidence File(s)	IAM_PrivEsc_Report.pdf

Actions Taken

Consolidated the lab setup, policy-analysis results, privilege-escalation findings, risk assessment, mitigations, business impact, and reflection responses into the EncryptEdge Labs reporting structure.

Key Observations

The combined analysis shows that IAM privilege escalation is primarily a permissions-governance problem: excessive identity-management rights can undermine otherwise limited roles. Reporting the path, business consequence, and control owner together makes remediation more actionable.

Evidence Produced

- IAM_PrivEsc_Report.pdf — final task report.

4.0 Findings

The assessment produced three significant IAM findings. The highest-priority issue was the presence of privilege-escalation paths that could allow a lower-privileged identity to modify authentication or policy state and obtain stronger access. Resource exposure and infrastructure-modification permissions were also identified as control weaknesses requiring least-privilege remediation.

4.1 Findings Summary

#	Finding Title	Type / Category	Cloud Service / Resource	MITRE Ref.	Phase	Severity	Evidence Ref.
1	IAM privilege-escalation path	Privilege Escalation Path	IAM roles / users	T1098 / T1068	C	Critical	phaseC_graph.png
2	Resource exposure from weak IAM constraints	Access Control Weakness	IAM policies	T1078	A	High	Cloudsplaining report

#	Finding Title	Type / Category	Cloud Service / Resource	MITRE Ref.	Phase	Severity	Evidence Ref.
3	Infrastructure modification permissions	IAM Policy Gap	IAM policies / resources	T1098	A/D	Medium	Cloudsplaining report / risk matrix

4.2 Detailed Finding Analysis

Finding 1: IAM privilege-escalation path

Finding Title	IAM privilege-escalation path
Type / Category	Privilege Escalation Path
Cloud Service / Resource	IAM roles and users
Description	PMapper identified relationships where IAM login-profile modification permissions could be used to access more privileged principals. This demonstrates a practical escalation path from delegated identity-management rights to stronger account access.
How Identified	PMapper graph creation, analysis output, and privilege-escalation visualization.
MITRE ATT&CK Reference	T1098 (Account Manipulation); T1068 (Exploitation for Privilege Escalation)
Business / Security Impact	Successful exploitation could compromise confidentiality and integrity by allowing an attacker to obtain higher privileges, modify IAM state, access protected resources, and potentially establish persistence.
Severity / Impact	Critical
Evidence Reference	phaseC_graph.png

Finding 2: Resource exposure from weak IAM constraints

Finding Title	Resource exposure from weak IAM constraints
Type / Category	Access Control Weakness
Cloud Service / Resource	IAM policies / protected resources
Description	Cloudsplaining reported a High-severity resource-exposure finding, indicating that one or more permissions were insufficiently constrained by resource ARN or equivalent scope restrictions.

How Identified	Cloudsplaining static IAM policy assessment.
MITRE ATT&CK Reference	T1078 (Valid Accounts)
Business / Security Impact	A compromised valid identity could use broadly scoped permissions against more resources than intended, increasing the blast radius and potential for unauthorized data or service access.
Severity / Impact	High
Evidence Reference	Cloudsplaining assessment screenshot/report

Finding 3: Infrastructure modification permissions

Finding Title	Infrastructure modification permissions
Type / Category	IAM Policy Gap
Cloud Service / Resource	IAM policies / infrastructure resources
Description	Cloudsplaining reported an infrastructure-modification finding. Although rated lower than the privilege-escalation findings, modification rights can still be combined with other permissions to weaken controls or alter cloud resources.
How Identified	Cloudsplaining static IAM policy assessment and Phase D risk review.
MITRE ATT&CK Reference	T1098 (Account Manipulation)
Business / Security Impact	Unauthorized changes could affect integrity and availability, create persistence, or make later privilege escalation easier.
Severity / Impact	Medium
Evidence Reference	Cloudsplaining assessment / Phase D risk matrix

5.0 Risk Assessment & Cloud Threat Model

5.1 Cloud Security Control Gaps & Defensive Coverage

[For each significant finding, describe which AWS-native or third-party control could detect, prevent, or reduce the risk. Consider: CloudTrail rules, AWS Config rules, GuardDuty detectors, IAM Access Analyzer, Security Hub checks, S3 Block Public Access, SCPs, or CloudWatch alarms.]

Finding / Gap	Observable / Trigger in Cloud Telemetry	Recommended Control	AWS Service / Tool for Implementation
IAM privilege-escalation path	CloudTrail events such as PutRolePolicy, AttachUserPolicy, CreateLoginProfile, UpdateLoginProfile, PassRole, AssumeRole	Remove unnecessary IAM write permissions; apply permission boundaries/SCP guardrails; alert on high-risk IAM changes	AWS IAM, Organizations SCPs, CloudTrail, CloudWatch, IAM Access Analyzer
Resource exposure	Use of broad resource scopes or unexpected resource access	Constrain policies to specific ARNs and conditions; periodically scan policies	IAM policy review, Cloudsplaining, IAM Access Analyzer
Infrastructure modification	High-risk resource-modification API events	Reduce modification permissions and require approved roles/workflows	IAM, CloudTrail, CloudWatch, Security Hub

5.2 Risk Exposure Over Time

Risk 1 — IAM privilege escalation:

If the identified escalation paths remain available, compromise of a lower-privileged identity could become compromise of a more powerful principal. Over time, this increases the likelihood of persistent access, unauthorized policy changes, and broader compromise of cloud resources.

Risk 2 — Resource exposure:

Broad or insufficiently resource-scoped permissions expand the blast radius of valid credentials. A single compromised identity may reach resources outside its intended job function, increasing confidentiality and compliance risk.

Risk 3 — Infrastructure modification:

Modification permissions can be chained with other IAM weaknesses to alter services, weaken controls, or create persistence. Even when individually rated lower, they should be reviewed as part of the complete privilege graph rather than in isolation.

6.0 Recommendations

Recommendations below directly address the three findings identified in Section 4.

6.1 Technical Remediation

#	Finding	Specific Remediation Action (with Policy / CLI where applicable)	Priority	Standard / Reference
1	IAM privilege-escalation path	Remove or tightly scope IAM write actions such as PutRolePolicy, AttachUserPolicy, CreateLoginProfile, UpdateLoginProfile, PassRole and AssumeRole. Use permission boundaries and SCPs to prevent unauthorized privilege growth.	Immediate	Least privilege; ISO/IEC 27001 access control; MITRE T1098 mitigation
2	Resource exposure	Replace wildcard or overly broad resource scope with approved resource ARNs and conditions; validate with policy analysis before deployment.	Immediate	Least privilege; IAM Access Analyzer / policy review
3	Infrastructure modification permissions	Restrict modification APIs to dedicated administrative roles and monitor change events through CloudTrail/CloudWatch.	Short-term	ISO/IEC 27001 change/access control; AWS logging best practices

6.2 Strategic & Operational Improvements

Strategic improvements should combine preventive IAM governance with continuous detection:

- Establish reusable least-privilege IAM role patterns and require peer review for any policy containing IAM write actions or wildcard resources.
- Apply organization-level guardrails, including SCPs and permission boundaries, to block unauthorized privilege-escalation actions even if an individual policy is misconfigured.
- Alert on high-risk IAM changes in CloudTrail, especially policy attachment, inline policy creation, login-profile changes, role passing, and role assumption.
- Re-run Cloudsplaining and PMapper after IAM changes so newly introduced privilege paths are detected before they become persistent risk.
- Track remediation through a centralized risk register with an owner, due date, affected account, severity, and validation status.

7.0 Reflection

Q1 How would you prioritize remediation if multiple high-risk policies are discovered across different accounts?

I would prioritize by combining exploitability, privilege gained, resource sensitivity, account criticality, and exposure. A direct path to administrator access in a production or shared-services account would be remediated before an isolated lower-impact issue. I would also look for common policy templates so one fix can remove the same weakness across multiple accounts, then validate the change with repeated policy and graph analysis.

Q2 What business risks arise when developers are granted broad iam:* permissions?

Broad iam:* permissions allow developers or compromised developer credentials to change identities, policies, trust relationships, and authentication settings. This can lead to unauthorized administrative access, data exposure, service disruption, persistence, and loss of separation of duties. It also increases audit and compliance risk because privilege boundaries become difficult to demonstrate and enforce.

Q3 How can continuous monitoring tools detect new privilege escalation paths over time?

Continuous monitoring can combine IAM configuration snapshots, policy scanners, relationship graphs, and CloudTrail alerts. Tools such as Cloudsplaining or PMapper can be re-run after IAM changes to identify new risky permissions or paths, while CloudTrail and CloudWatch can alert when sensitive IAM APIs are used. This reduces the time between creation of a risky permission and security-team awareness.

Q4 If you were presenting your findings to executives, how would you communicate technical risks in business terms?

I would describe the issue as a path that can turn a limited account into a powerful account, increasing the impact of credential compromise. I would focus on business outcomes: unauthorized access to sensitive information, disruption of cloud services, regulatory exposure, and incident-response cost. I would then show the number of critical/high paths, affected business systems, remediation ownership, and expected risk reduction after fixes.

8.0 Deliverables Submission Checklist

Deliverables are listed below using the evidence currently available. Items not supplied at report-generation time are marked Pending.

✓	Phase	Deliverable Description	Your Filename	Status
☒	Phase A	IAM policy risk assessment / Cloudsplaining evidence	Cloudsplaining assessment screenshot/report	Complete
☒	Phase B	Docker homelab setup evidence	phaseB_docker.png	Complete
☒	Phase C	Privilege-escalation graph evidence	phaseC_graph.png	Complete

✓	Phase	Deliverable Description	Your Filename	Status
☒	Phase D	Risk assessment and mitigation analysis	Risk matrix included in report	Complete
☐	Phase E	Cybr hosted lab completion evidence	phaseE_lab_results.png	Pending
☒	Report	Final IAM privilege-escalation report	IAM_PrivEsc_Report.pdf	Complete

Submission naming convention:

- Report PDF: IAM_PrivEsc_Report.pdf
- Evidence folder: CSE-IAM-L-026-04_Evidence_SK/ — include all phase evidence files before submission.

9.0 Additional Observations

During the task, several environment/tool issues required troubleshooting. Docker was initially unavailable inside WSL and later returned a socket-permission error; WSL integration and Docker group access resolved the issue. PMapper also encountered Python-version compatibility problems and regional AWS endpoint timeouts. Restricting graph creation to the intended region allowed the IAM graph and privilege-escalation visualization to be produced successfully.

Declaration & Sign-Off

I confirm that:

- All work in this report is my own except where AI usage is explicitly declared in Section 2.3.
- All technical activities were performed exclusively within the authorised cloud environments listed in Section 1.3.
- No external AWS accounts, production environments, third-party cloud resources, or real customer data were accessed during this task.
- All AWS credentials, access keys, session tokens, and account identifiers used during this task have been redacted in evidence files before submission.
- I have reviewed this report for accuracy, completeness, and professional presentation before submission.

Intern Full Name	Signature	Date of Submission
		31 August 2026

EncryptEdge Labs Limited — Junior Cloud Security Engineer Internship Programme

Company No. 15830711 | United Kingdom | encryptedgelabs.com

Copyright © 2026 EncryptEdge Labs. All rights reserved. | Report Template v3.0